Sicurezza dei Sistemi Informativi

Appello d'Esame del 25 Giugno 2024

Anno Accademico 2023-2024

Politecnico di Torino — Docente: Prof. Cataldo Basile

2024-06-25

1 Testo Ufficiale dell'Esame

Domanda 1: Domande a Scelta Multipla (Vulnerabilità e Protezione)

Valutare la correttezza delle seguenti affermazioni:

a. Una vulnerabilità di tipo buffer overflow sullo stack permette a un attaccante di sovrascrivere il frame pointer (Saved EBP/RBP) e l'indirizzo di ritorno (Saved EIP/RIP).

b. La tecnica ASLR (Address Space Layout Randomization) rende completamente impossibili gli attacchi basati su Return-Oriented Programming (ROP).

c. Gli stack canaries sono valori casuali inseriti prima dell'indirizzo di ritorno che vengono verificati prima dell'uscita della funzione per rilevare la corruzione dello stack.

d. Il meccanismo Data Execution Prevention (DEP / NX bit) impedisce l'esecuzione di codice presente nelle sezioni stack e heap della memoria.

e. Il processo di Reverse Engineering su codice compilato produce sempre come output il codice sorgente originale identico a quello scritto dallo sviluppatore.

Domanda 2: Phishing Avanzato, Pretexting e Debolezze Umane

Spiegare cosa sono il **Phishing** e il **Pretexting**, evidenziando le differenze tra le due tecniche. Descrivere le varianti principali del phishing:

- Spear Phishing;
- Whaling;
- Vishing e Smishing.

Indicare quali debolezze psicologiche e cognitive umane vengono sfruttate (es. autorità, urgenza, timore di sanzioni, avidità) e proporre un piano di contromisure integrato (tecnologiche e formative).

Domanda 3: Esercizio di Progettazione Architetturale Screened Subnet

Un'organizzazione deve dividere la propria infrastruttura in due livelli di sicurezza distinti:

- Rete a livello di sicurezza più basso (può accedere direttamente ad Internet);

- Rete a livello di sicurezza più elevato (separata da Internet e accessibile solo attraverso la rete a livello più basso tramite rigide regole di autorizzazione);
- Due server aziendali che erogano servizi critici devono essere raggiungibili anche da Internet.

Progettare la topologia di rete, specificare il posizionamento dei dispositivi di sicurezza (firewall, router, DMZ) e compilare la matrice delle regole di autorizzazione.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Valutazione Crocette

- **a. VERA**: Un buffer overflow classico su array allocati sullo stack consente, scrivendo oltre la dimensione consentita, di sovrascrivere variabili locali, il Saved Frame Pointer e il Return Address, deviando il flusso di esecuzione.
- **b. FALSA**: L'ASLR randomizza gli indirizzi base delle librerie e dello stack, ma NON rende impossibili gli attacchi ROP; un attaccante può aggirarla tramite *Information Disclosure / Memory Leak* per calcolare l'indirizzo base a runtime, oppure effettuare attacchi di forza bruta (in sistemi a 32 bit).
- **c. VERA**: Lo stack canary è una sentinella posta tra le variabili locali e il return address; se l'epilogo della funzione rileva un valore alterato, il programma invoca immediatamente `__stack_chk_fail` terminando l'esecuzione.
- **d. VERA**: Il flag NX/XD (*No-Execute*) a livello di paginazione di memoria hardware impedisce alla CPU di eseguire istruzioni fetchate da pagine marcate come dati (stack e heap), forzando gli attaccanti a passare ad attacchi di tipo code-reuse (Return-to-libc, ROP).
- **e. FALSA**: Il compilatore elimina nomi di variabili locali, commenti, tipi complessi e macro; i decompilatori moderni (Ghidra, Hex-Rays) ricostruiscono una rappresentazione ad alto livello approssimata, non il sorgente identico originario.

Soluzione Domanda 2: Phishing, Pretexting e Psicologia dell'Ingegneria Sociale

Phishing vs Pretexting:

- **Phishing**: Attacco condotto tipicamente in massa via email o messaggistica che induce le vittime a compiere un'azione immediata (cliccare su un link clone o aprire un malware allegato).
- **Pretexting**: Creazione di uno scenario fittizio credibile e articolato (un "pretesto") in cui l'attaccante impersona una figura autorevole o di fiducia (es. auditor esterno, supporto IT, personale delle forze dell'ordine) per instaurare una relazione e farsi consegnare informazioni riservate nel corso di più interazioni.

Varianti del Phishing:

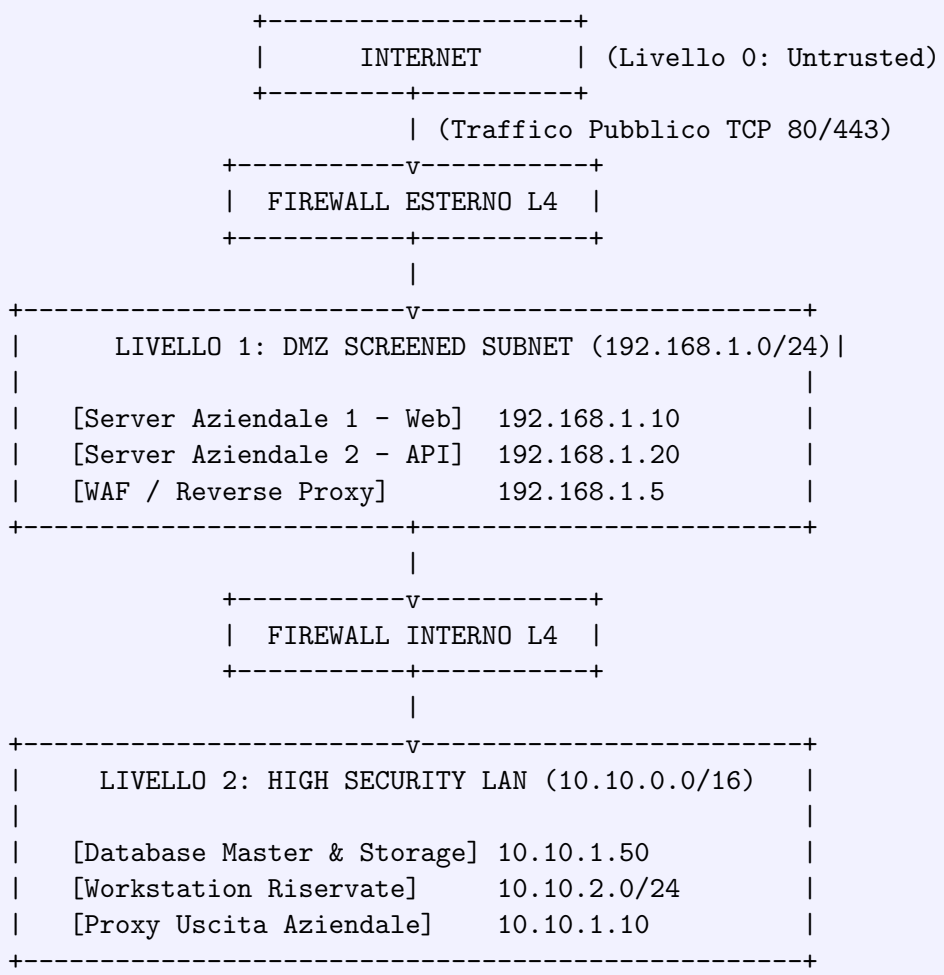
- *Spear Phishing*: Attacco altamente mirato contro un individuo o reparto specifico, personalizzato raccogliendo informazioni preliminari OSINT.
- *Whaling*: Spear phishing diretto contro figure apicali aziendali (CEO, CFO, membri del CDA) con l'obiettivo di frodi finanziarie ingenti (es. CEO Fraud / Business Email Compromise).
- *Vishing (Voice Phishing)*: Condotto telefonicamente, spesso oggi integrato con audio deepfake vocale generativo.
- *Smishing*: Condotto tramite SMS contenenti link ingannevoli per intercettare credenziali o codici OTP SMS.

Debolezze Psicologiche Sfruttate: Senso di urgenza artificioso, timore di sanzioni o blocco conto, principio di autorità, compiacenza e curiosit:
Contromisure:

- *Tecniche*: Adozione di chiavi hardware FIDO2 (resistenti al phishing), autenticazione email (DMARC su policy reject), sandboxing avanzato delle email in ingresso.
- *Formative*: Campagne periodiche di simulazione phishing con debriefing immediato e cultura aziendale priva di colpevolizzazione (*no-blame culture*).

Soluzione Domanda 3: Topologia a Due Livelli di Sicurezza e DMZ

Architettura Progettata (Screened Subnet a Due Livelli di Sicurezza): Si adotta una struttura perimetrale a zone gerarchiche con due linee di difesa firewall distinte (Two-Tier Architecture):



Subnetting, Instradamento e Flussi di Traffico:

- **Livello 0 (Untrusted / Internet)**: Accesso pubblico consentito esclusivamente verso il WAF/Server 1 e Server 2 in DMZ su porte TCP 80 e 443 tramite Destination NAT (DNAT). Nessun pacchetto esterno può mai raggiungere il Livello 2.
- **Livello 1 (DMZ,** `192.168.1.0/24`**)**: Gateway `192.168.1.1` su Firewall Esterno e `192.168.1.2` su Firewall Interno. Ospita i server critici esposti. In caso di com-

promissione di un server in DMZ, il Firewall Interno blocca rigorosamente qualsiasi movimento laterale verso la LAN interna.

- **Livello 2 (High Security LAN,** `10.10.0.0/16`): Gateway `10.10.0.1`. Rete completamente schermata e isolata. Può raggiungere i server in DMZ solo per manutenzione su porte specifiche (SSH TCP 22 / SQL TCP 5432). L'uscita verso Internet è mediata e filtrata da un proxy aziendale autenticato (`10.10.1.10`).

Matrice delle Regole di Autorizzazione:

Origine	Destinazione	Protocollo/Porta	Azione	Motivazione
Internet	DMZ (Server 1, 2)	TCP 80, 443	**PERMIT**	Esposizione dei due servizi pubblici aziendali
Internet	High Security LAN	Qualsiasi	**DENY**	Isolamento assoluto della rete interna da Internet
High Security LAN	DMZ	Porte dedicate	**PERMIT**	Amministrazione e aggiornamento dei server in DMZ
High Security LAN	Internet	TCP 80, 443	**PERMIT**	Uscita web mediata da proxy aziendale
DMZ	High Security LAN	Qualsiasi	**DENY**	Previene movimenti laterali in caso di compromissione server DMZ

Alternative Implementation Note: Rust per Software Anti-Exploit

In Rust, la gestione della memoria è verificata staticamente dal *borrow checker* del compilatore:

- Le vulnerabilità di stack overflow, buffer overflow e use-after-free sono **impossibili a tempo di compilazione** nel codice Safe Rust.
- Per la programmazione concorrente sicura senza race condition, si utilizzano tipi RAII standard come `std::sync::Mutex` e `std::sync::mpsc`.